Beyond simply requiring that users are authenticated, we may also want to impose additional restrictions on who can use certain operations. In this chapter, you'll implement a very simple access control method based upon whether a user is a member of the social space they are trying to access. You'll accomplish this by keeping track of which users are members of which social spaces in a structure known as an *access control list* (ACL). You can think of the ACL like a list of names given to a nightclub security guard – "If your name's not down, you're not coming in!".

Each entry for a space will list a user that may access that space, along with a set of *permissions* that define what they can do. You can define three permissions: read messages in the space, post messages to that space, and a delete permission granted to moderators.

> **DEFINITION** An ***access control list*** is a list of users that can access a given object, together with a set of ***permissions*** that define what that user can do.

Why not simply let all authenticated users perform any operation? In some APIs this may be an appropriate security model, but for most APIs some operations are more sensitive than others. For example, you might let anyone in your company see their own salary information in your payroll API, but the ability to change somebody's salary is not normally something you would allow any employee to do! There is an important security principle, known as the *principle of least authority* (POLA), which says that any user (or process) should be given exactly the right amount of authority (permissions) to do the jobs they need to do. Too